

THINK BEYOND PRACTICE LLC BUSINESS ASSOCIATE AGREEMENT

BAA Version 1.0 — May 2026

This Business Associate Agreement (“Agreement”) is entered into between Think Beyond Practice LLC, a Washington limited liability company (“Business Associate”), and the individual clinician, professional practice, or healthcare entity accepting this Agreement (“Covered Entity”). Business Associate and Covered Entity may be referred to individually as a “Party” and collectively as the “Parties.”

This Agreement is incorporated into and supplements the Terms of Service between the Parties (the “Service Agreement”). In the event of any conflict between this Agreement and the Service Agreement with respect to the handling of Protected Health Information, this Agreement shall control.

By accepting this Agreement, Covered Entity represents that the individual accepting has the authority to bind Covered Entity to this Agreement.

1. Definitions

Capitalized terms used in this Agreement and not otherwise defined shall have the meanings given to them under the Health Insurance Portability and Accountability Act of 1996 (“HIPAA”), as amended by the Health Information Technology for Economic and Clinical Health Act (“HITECH Act”), and the regulations promulgated thereunder at 45 C.F.R. Parts 160 and 164 (collectively, the “HIPAA Rules”). For convenience, certain key terms are defined below.

1.1 “Breach” has the meaning given in 45 C.F.R. § 164.402.

1.2 “Business Associate” means Think Beyond Practice LLC, in its capacity as a business associate to Covered Entity under this Agreement.

1.3 “Covered Entity” means the clinician, professional practice, or healthcare entity that has entered into this Agreement with Business Associate.

1.4 “Designated Record Set” has the meaning given in 45 C.F.R. § 164.501.

1.5 “Electronic Protected Health Information” or “ePHI” has the meaning given in 45 C.F.R. § 160.103, limited to information created, received, maintained, or transmitted by Business Associate on behalf of Covered Entity through the Platform.

1.6 “Individual” has the meaning given in 45 C.F.R. § 160.103 and includes a person who qualifies as a personal representative under 45 C.F.R. § 164.502(g).

1.7 “Platform” means the Think Beyond Practice software platform, including Practice Manager, Credentialing Hub, and any other current or future Platform features through which Business Associate creates, receives, maintains, or transmits PHI on behalf of Covered Entity.

1.8 “Protected Health Information” or “PHI” has the meaning given in 45 C.F.R. § 160.103, limited to information created, received, maintained, or transmitted by Business Associate from or on behalf of Covered Entity through the Platform.

1.9 “Required by Law” has the meaning given in 45 C.F.R. § 164.103.

1.10 “Secretary” means the Secretary of the United States Department of Health and Human Services or her designee.

1.11 “Security Incident” has the meaning given in 45 C.F.R. § 164.304.

1.12 “Subcontractor” has the meaning given in 45 C.F.R. § 160.103.

1.13 “Unsuccessful Security Incident” means an incident such as a “ping” or other unsuccessful attempt to access a network, an unsuccessful login attempt, network probe, port scan, malware that is detected and contained without harm, or similar event that, individually and in the aggregate, does not result in actual compromise of PHI.

2. Obligations and Activities of Business Associate

2.1 Permitted Uses and Disclosures. Business Associate shall not use or disclose PHI other than as permitted or required by this Agreement, the Service Agreement, or as Required by Law. Specifically, Business Associate may use and disclose PHI only: (a) To perform functions, activities, and services for or on behalf of Covered Entity as described in the Service Agreement; (b) For the proper management and administration of Business Associate or to carry out the legal responsibilities of Business Associate, provided that any disclosure for such purposes is either Required by Law or made under written assurances from the recipient that the PHI will be held confidentially, used or further disclosed only as Required by Law or for the purpose for which it was disclosed, and that the recipient will notify Business Associate of any breach of confidentiality; (c) To provide data aggregation services relating to the healthcare operations of Covered Entity, if requested by Covered Entity; (d) As Required by Law.

2.2 Use Restrictions. Business Associate shall: (a) Not use or disclose PHI in a manner that would violate the HIPAA Rules if done by Covered Entity, except as expressly permitted under 45 C.F.R. §§ 164.504(e)(2)(i)(A) or (B); (b) Not use or disclose PHI for marketing purposes or to sell PHI, except as permitted under HIPAA Rules and only with Covered Entity’s written authorization; (c) Not use PHI received from or on behalf of Covered Entity to develop, train, or improve any artificial intelligence model, machine learning model, or similar system. This restriction does not prohibit Business Associate from using de-identified data, aggregated data, synthetic data, content explicitly contributed by Covered Entity under the Service Agreement’s user-generated content provisions, or other data that does not constitute PHI for AI development purposes; (d) Limit its use, disclosure, and request of PHI to the minimum necessary to accomplish the intended purpose, in accordance with 45 C.F.R. §§ 164.502(b) and 164.514(d).

2.3 Safeguards. Business Associate shall implement and maintain appropriate administrative, physical, and technical safeguards, and shall comply with the applicable provisions of Subpart C of 45 C.F.R. Part 164 with respect to ePHI, to: (a) Prevent use or disclosure of PHI other than as provided for by this Agreement; (b) Reasonably protect the confidentiality, integrity, and availability of ePHI that Business Associate creates, receives, maintains, or transmits on behalf of Covered Entity.

Business Associate’s safeguards include, without limitation: Encryption of ePHI in transit and at rest where applicable; Access controls limiting employee and Subcontractor access to PHI on a least-privilege basis; Audit logging of administrative access to systems that process PHI; Authentication controls including support for multi-factor authentication; Data minimization practices including limited retention of patient information processed through the Platform, in accordance with the Platform’s data flow design; Vendor management procedures for Subcontractors; Workforce training on HIPAA obligations; Incident response and breach

notification procedures.

2.4 Reporting Obligations. Business Associate shall: (a) Report to Covered Entity any use or disclosure of PHI not provided for by this Agreement of which Business Associate becomes aware; (b) Report to Covered Entity any Security Incident of which Business Associate becomes aware, except that the Parties acknowledge and agree that this Section constitutes notice to Covered Entity of the regular occurrence of Unsuccessful Security Incidents, for which no further notification is required; (c) Report any Breach of unsecured PHI in accordance with Section 4 of this Agreement.

2.5 Subcontractors. Business Associate shall ensure that any Subcontractor that creates, receives, maintains, or transmits PHI on behalf of Business Associate agrees in writing to substantially the same restrictions, conditions, and requirements that apply to Business Associate under this Agreement, in accordance with 45 C.F.R. § 164.502(e)(1)(ii). Business Associate shall maintain Business Associate Agreements with all such Subcontractors. A current list of Subcontractors that may process PHI is available at thinkbeyondpractice.com/subprocessors.

2.6 Access to PHI. The Parties acknowledge that the Platform is not designed to maintain a Designated Record Set on behalf of Covered Entity. Patient information processed through the Platform is delivered to Covered Entity, who is responsible for maintaining the Designated Record Set within Covered Entity's own records system (such as Covered Entity's electronic health record). To the extent Business Associate retains any PHI in a form that constitutes part of a Designated Record Set, Business Associate shall, within thirty (30) business days of a written request from Covered Entity, provide access to such PHI to enable Covered Entity to comply with 45 C.F.R. § 164.524.

2.7 Amendment of PHI. Consistent with Section 2.6, the Platform is not designed to maintain a Designated Record Set, and amendments to patient records are made by Covered Entity within Covered Entity's own records system. To the extent Business Associate retains any PHI in a form that constitutes part of a Designated Record Set, Business Associate shall, within thirty (30) business days of a written request from Covered Entity, make any amendment to such PHI that Covered Entity directs or agrees to in accordance with 45 C.F.R. § 164.526.

2.8 Accounting of Disclosures. Business Associate shall maintain records of disclosures of PHI as required by 45 C.F.R. § 164.528 and shall, within thirty (30) business days of a written request from Covered Entity, provide an accounting of disclosures sufficient to enable Covered Entity to respond to an Individual's request under 45 C.F.R. § 164.528.

2.9 Documentation and Records. Business Associate shall make its internal practices, books, and records, including policies and procedures and PHI, relating to the use and disclosure of PHI received from, or created or received by Business Associate on behalf of, Covered Entity, available to the Secretary for purposes of determining Covered Entity's compliance with the HIPAA Rules.

2.10 Mitigation. Business Associate shall take reasonable steps to mitigate, to the extent practicable, any harmful effect that is known to Business Associate of a use or disclosure of PHI in violation of this Agreement.

2.11 Compliance with HIPAA Security Rule. To the extent Business Associate creates, receives, maintains, or transmits ePHI on behalf of Covered Entity, Business Associate shall comply with the applicable requirements of the HIPAA Security Rule (Subpart C of 45 C.F.R. Part 164).

2.12 Email and Messaging Channels. The Parties acknowledge that certain Platform features may transmit PHI to Covered Entity through email or other messaging channels (for example, delivery of patient assessment results, letter generator outputs, or notification messages). Business Associate maintains a Business Associate Agreement with the email service provider through which such transmissions are routed, and applies appropriate technical safeguards to such transmissions. Covered Entity acknowledges and agrees that Covered Entity is responsible for the security of Covered Entity's own email environment, including the email address and account through which Covered Entity receives Platform communications. Business Associate's safeguards do not extend to email systems or environments outside of Business Associate's control.

3. Obligations and Activities of Covered Entity

3.1 Notice of Privacy Practices. Covered Entity shall notify Business Associate of any limitation(s) in its notice of privacy practices, to the extent such limitation may affect Business Associate's use or disclosure of PHI.

3.2 Changes in Authorization. Covered Entity shall notify Business Associate of any changes in, or revocation of, the permission by an Individual to use or disclose PHI, to the extent such changes may affect Business Associate's use or disclosure of PHI.

3.3 Restrictions. Covered Entity shall notify Business Associate of any restriction on the use or disclosure of PHI that Covered Entity has agreed to or is required to abide by under 45 C.F.R. § 164.522, to the extent such restriction may affect Business Associate's use or disclosure of PHI.

3.4 Permissible Requests. Covered Entity shall not request Business Associate to use or disclose PHI in any manner that would not be permissible under the HIPAA Rules if done by Covered Entity, except as expressly permitted for a business associate under HIPAA.

3.5 Appropriate Use of Platform. Covered Entity shall: (a) Use the Platform in accordance with the Service Agreement and any documentation provided by Business Associate; (b) Submit PHI only through Platform features designed to handle PHI; (c) Obtain any patient consents, authorizations, or notices required by HIPAA, state law, or applicable professional standards before using Platform features that process patient information; (d) Maintain the security of Covered Entity's account credentials and notify Business Associate promptly of any suspected compromise; (e) Comply with Covered Entity's own HIPAA obligations as a covered entity, including risk assessments, workforce training, and policies and procedures.

4. Breach Notification

4.1 Notification of Breach. Business Associate shall notify Covered Entity of any Breach of Unsecured PHI without unreasonable delay and in no case later than sixty (60) calendar days after discovery of the Breach. Discovery shall be deemed to have occurred as defined in 45 C.F.R. § 164.410(a)(2).

4.2 Content of Notification. The notification provided under Section 4.1 shall include, to the extent possible: (a) The identification of each Individual whose Unsecured PHI has been, or is reasonably believed by Business Associate to have been, accessed, acquired, used, or disclosed during the Breach; (b) A description of what happened, including the date of the Breach and the date of discovery; (c) A description of the types of Unsecured PHI involved; (d) A description of any steps Individuals should take to protect themselves from potential harm resulting from the Breach; (e) A description of what Business Associate is

doing to investigate the Breach, mitigate harm, and prevent further Breaches; (f) Contact information for Individuals to ask questions or learn additional information.

4.3 Cooperation. Business Associate shall cooperate with Covered Entity in any investigation of a Breach and in any notification Covered Entity may be required to make to Individuals, the Secretary, or the media under 45 C.F.R. §§ 164.404, 164.406, and 164.408.

4.4 Costs. Reasonable costs of Breach notification, mitigation, and remediation shall be allocated as follows: each Party shall bear the costs attributable to its own actions or omissions giving rise to the Breach. Where the Breach results from a failure of Business Associate's safeguards or those of Business Associate's Subcontractors, Business Associate shall bear the reasonable costs of Breach notification and mitigation, subject to the limitations of liability set forth in the Service Agreement.

5. Term and Termination

5.1 Term. This Agreement shall be effective as of the date of Covered Entity's acceptance and shall remain in effect until terminated as provided in this Section, or until the termination of the Service Agreement, whichever is earlier.

5.2 Termination for Cause. Upon Covered Entity's knowledge of a material breach of this Agreement by Business Associate, Covered Entity shall provide Business Associate with written notice of the breach and a reasonable opportunity (not less than thirty (30) days) to cure. If Business Associate does not cure the breach within the cure period, Covered Entity may terminate this Agreement and the Service Agreement, or, if termination is not feasible, report the breach to the Secretary. Upon Business Associate's knowledge of a material breach of this Agreement by Covered Entity, Business Associate shall have the same right to provide notice, cure period, and termination.

5.3 Effect of Termination. (a) Return or Destruction of PHI. Upon termination of this Agreement, Business Associate shall, if feasible, return to Covered Entity or destroy all PHI received from Covered Entity, or created, maintained, or received by Business Associate on behalf of Covered Entity, that Business Associate then maintains in any form. Business Associate shall retain no copies of such PHI. (b) Infeasibility of Return or Destruction. If Business Associate determines that returning or destroying PHI is infeasible, Business Associate shall provide Covered Entity with written notification of the conditions making return or destruction infeasible. Business Associate shall extend the protections of this Agreement to the PHI not returned or destroyed and limit further uses and disclosures of such PHI to those purposes that make return or destruction infeasible, for so long as Business Associate maintains such PHI. (c) Acknowledgment of Limited Retention. The Parties acknowledge that, by design, the Platform processes patient information transiently and does not retain PHI for ongoing storage beyond what is necessary to deliver the requested outputs to Covered Entity. Therefore, at the time of termination, Business Associate may hold little or no PHI in operational systems subject to return or destruction. Patient information may persist transiently in encrypted backups during normal backup rotation, after which it is destroyed.

5.4 Survival. The obligations of Business Associate under Sections 2.4, 2.5, 2.10, 4, 5.3, and 6 shall survive the termination of this Agreement.

6. Miscellaneous

6.1 Regulatory References. A reference in this Agreement to a section in the HIPAA Rules means the section as in effect or as amended.

6.2 Amendment. The Parties agree to take such action as is necessary to amend this Agreement from time to time as is necessary for compliance with the requirements of the HIPAA Rules and any other applicable law.

6.3 Survival. The respective rights and obligations of Business Associate that by their nature are intended to survive termination of this Agreement shall survive.

6.4 Interpretation. Any ambiguity in this Agreement shall be resolved in favor of a meaning that permits compliance with the HIPAA Rules.

6.5 No Third-Party Beneficiaries. Nothing in this Agreement shall be construed to create any rights or remedies in any third party, including any Individual, except as expressly required by the HIPAA Rules.

6.6 Relationship to Service Agreement. This Agreement is incorporated into and forms part of the Service Agreement. In the event of any conflict between this Agreement and the Service Agreement with respect to PHI, this Agreement shall control. In all other respects, the Service Agreement shall control.

6.7 Governing Law. This Agreement is governed by the laws of the State of Washington, without regard to conflict of law principles, except to the extent preempted by federal law.

6.8 Entire Agreement. This Agreement, together with the Service Agreement, constitutes the entire agreement between the Parties with respect to the subject matter hereof and supersedes all prior agreements, understandings, and communications regarding such subject matter.

6.9 Severability. If any provision of this Agreement is determined to be invalid or unenforceable, the remaining provisions shall remain in full force and effect.

6.10 Counterparts and Electronic Acceptance. This Agreement may be accepted electronically, and electronic acceptance shall have the same force and effect as a signed original.

6.11 Notices. Notices to Business Associate under this Agreement shall be sent to: Think Beyond Practice LLC, Attn: Privacy and Compliance, 9631 N Nevada St, Suite 209, Spokane, WA 99218, Email: privacy@thinkbeyondpractice.com. Notices to Covered Entity shall be sent to the contact information on file in Covered Entity's account.